
INCIDENT RESPONSE

Phishing Email Analysis & Investigation Report

Subject line: *"Unusual Login Activity Detected"*
Impersonated brand: Microsoft Security Team

Report reference	IR-2026-002
Incident type	Credential-harvesting phishing
Classification	Confirmed malicious
Severity	High
Date of report	17 September 2026
Prepared by	Security Analyst — Incident Response

1. Executive Summary

An unsolicited email claiming to originate from the “Microsoft Security Team” was received by the mailbox **sonyundefinedralph@gmail.com**. The message warned of unusual login activity from an unfamiliar device and pressured the recipient to verify their identity within 24 hours via an embedded shortened link, or face mailbox suspension.

Analysis confirms this is a **credential-harvesting phishing attempt**. The message was not sent from any Microsoft-owned infrastructure. It originated from **libreriacies.es**, an unrelated Spanish domain whose mail server is hosted on a shared Plesk platform in Granada, Spain. The embedded link was obfuscated behind a TinyURL redirect and is flagged as malicious by multiple independent security vendors.

Verdict	Confirmed phishing — malicious	Severity	High
Confidence	High	User interaction	None — link not clicked

Key findings at a glance

- The sender domain **libreriacies.es** has **no relationship whatsoever** to Microsoft, making the display name “Microsoft Security Team” a deliberate impersonation.
- The sending domain **publishes no DMARC record**, meaning there is no policy instructing receiving servers how to handle unauthenticated mail claiming to be from it.
- The embedded URL **https://tinyurl[.]com/ypu5kfts** was flagged as **malicious / phishing by 4 of 92 security vendors** on VirusTotal, including Fortinet, G-Data, ADMINUSLabs and SafeToOpen.
- The link now resolves to TinyURL’s own **spam interstitial page** (/app/nospam/), indicating the provider has independently identified and disabled the short link for abuse.
- The message exhibits the full standard phishing pattern: manufactured urgency, a 24-hour deadline, a threat of account loss, a generic salutation, an obfuscated link, and an unsolicited attachment.

Bottom line

This email should be treated as malicious. The link must not be clicked and the attachment must not be opened. Recommended containment and remediation actions are set out in Section 7.

2. Scope, Objectives & Methodology

2.1 Objectives

This investigation was conducted to answer four defined questions:

- Identify all Indicators of Compromise (IOCs) present within the email.
- Investigate the sender address and analyse the sender domain’s reputation and configuration.
- Safely analyse the embedded URL and determine whether it is malicious or suspicious.
- Reach a supported verdict on whether the message constitutes a phishing incident.

2.2 Methodology and tooling

All analysis was performed **passively**. At no point was the embedded link opened in a live browser, and the attachment was not executed. Investigation relied exclusively on open-source intelligence and third-party

sandboxing so that no interaction was signalled back to the attacker's infrastructure.

Tool	Purpose in this investigation
VirusTotal	Multi-engine reputation check on the embedded URL; retrieval of HTTP response metadata and content hash.
urlscan.io	Sandboxed rendering of sender infrastructure and the shortener domain; capture of redirects, contacted hosts and page screenshots.
MXToolbox	MX and DNS record enumeration for the sender domain; mail authentication (DMARC) posture check.
DNSDumpster	Passive DNS and infrastructure mapping; enumeration of exposed services and hosting provider attribution.

Analytical caution applied throughout

A “no classification” or “clean” result from a reputation service means only that the indicator has *not yet been catalogued* as malicious. It is not positive evidence of safety. Newly registered or newly abused infrastructure routinely returns clean verdicts during the earliest and most dangerous phase of a campaign. Findings in this report are therefore weighted on observed behaviour and message content, not solely on reputation scores.

3. The Reported Artefact

The email under analysis is reproduced below exactly as received. Note the mismatch between the claimed identity in the display name and the actual sending domain.

Subject	Unusual Login Activity Detected
Display name	Microsoft Security Team
Actual sender	info@libreriacies.es
Recipient	sonyundefinedralph@gmail.com
Embedded URL	https://tinyurl[.]com/ypu5kfts
Attachment	Present — referenced as a “security report”; not opened
Stated deadline	24 hours before claimed mailbox restriction

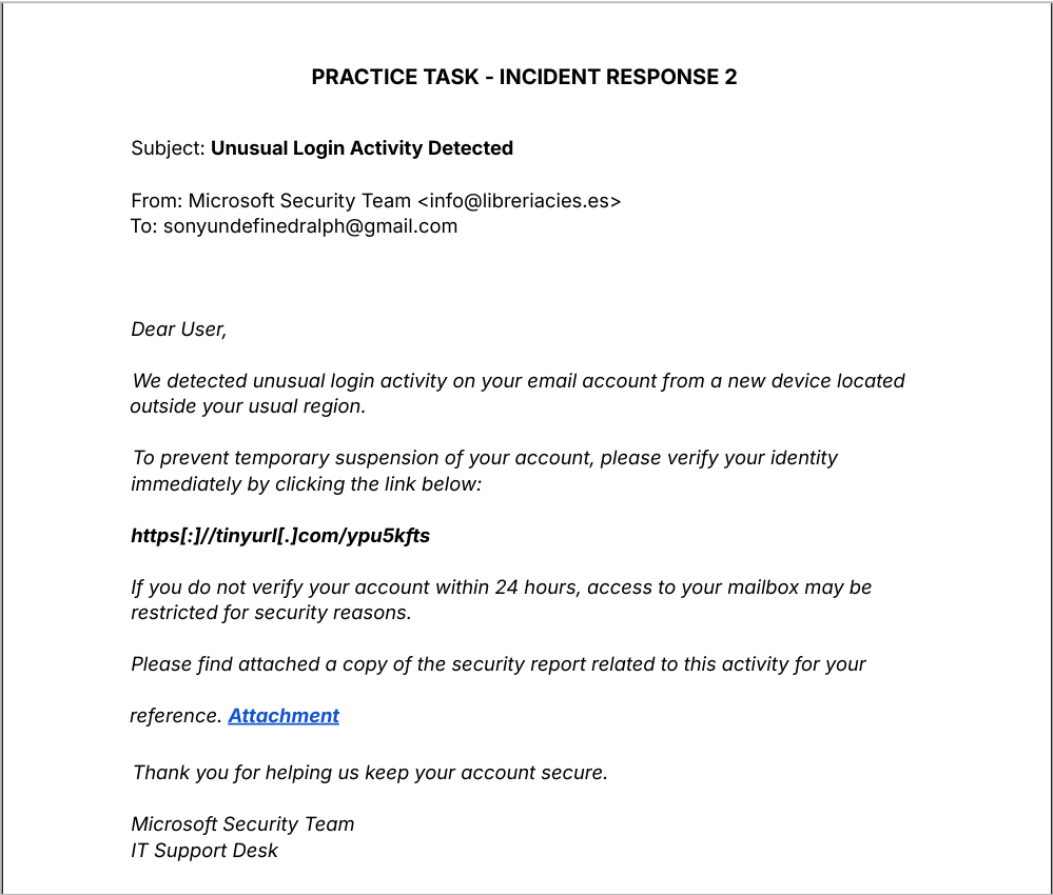


Figure 1 — The phishing email as received. The sender domain bears no relation to the impersonated brand, and the call to action is a shortened link.

4. Indicators of Compromise

The following indicators were extracted from the message. They are separated into **technical indicators** — atomic values suitable for blocking and threat hunting — and **behavioural indicators**, which describe the social-engineering tradecraft used.

4.1 Technical indicators

Type	Indicator	Assessment
Sender address	info@libreriacies.es	Malicious. Unrelated to the impersonated brand; used to deliver the lure.
Sender domain	libreriacies.es	Abused. Spanish domain on shared hosting; either compromised or attacker-controlled.
Mail server	mail.libreriacies.es	Resolves to a shared Plesk host; sole MX record for the domain.
Sender IP	217.18.161.43	Granada, Spain. AS42220 — Trevenque Sistemas de Información S.L.
Embedded URL	hxxps://tinyurl[.]com/ypu5kfts	Malicious. Flagged as phishing by 4 of 92 vendors on VirusTotal.
Content hash	787506f38a6d9e69a693f40b804c4f9f92c9330339cf367a9a0a0816ddf459a5	SHA-256 of the response body served by the link.
Attachment	“Security report” — unopened	Suspicious. Unsolicited attachment; potential second-stage payload.

4.2 Behavioural and social-engineering indicators

- **Brand impersonation.** The message presents itself as the Microsoft Security Team, but no Microsoft infrastructure is involved at any point in the delivery chain.
- **Manufactured urgency.** A 24-hour deadline is imposed to compress the recipient's decision-making and discourage verification through official channels.
- **Threat of loss.** The warning that mailbox access “may be restricted” applies fear of consequence, a standard coercion technique.
- **Generic salutation.** The message opens with “Dear User”. A legitimate provider security alert would reference the account holder and specific account details.
- **Link obfuscation.** The destination is concealed behind a URL shortener, preventing the recipient from inspecting the true target before clicking.
- **Unsolicited attachment.** A supposed “security report” is attached. Genuine providers direct users to sign in through the official portal rather than distributing files.
- **Vague technical claim.** “A new device located outside your usual region” is asserted with no device name, IP address, timestamp or location — details a real alert would always include.

5. Sender Domain & Infrastructure Analysis

5.1 DNS and mail configuration

An MX lookup on **libreriacies.es** returned a single mail exchanger, `mail.libreriacies.es`, at preference 10, resolving to **217.18.161.43** within AS42220 (Trevenque Sistemas de Información S.L.). DNS records are correctly published and the domain resolves normally.

Critically, the same lookup returned **no DMARC record** for the domain. DMARC instructs receiving mail servers what to do with messages that fail authentication checks. Its absence means there is no published enforcement policy, and mail claiming to come from this domain is far more likely to reach inboxes unchallenged. This is a material weakness that directly enables the abuse observed here.

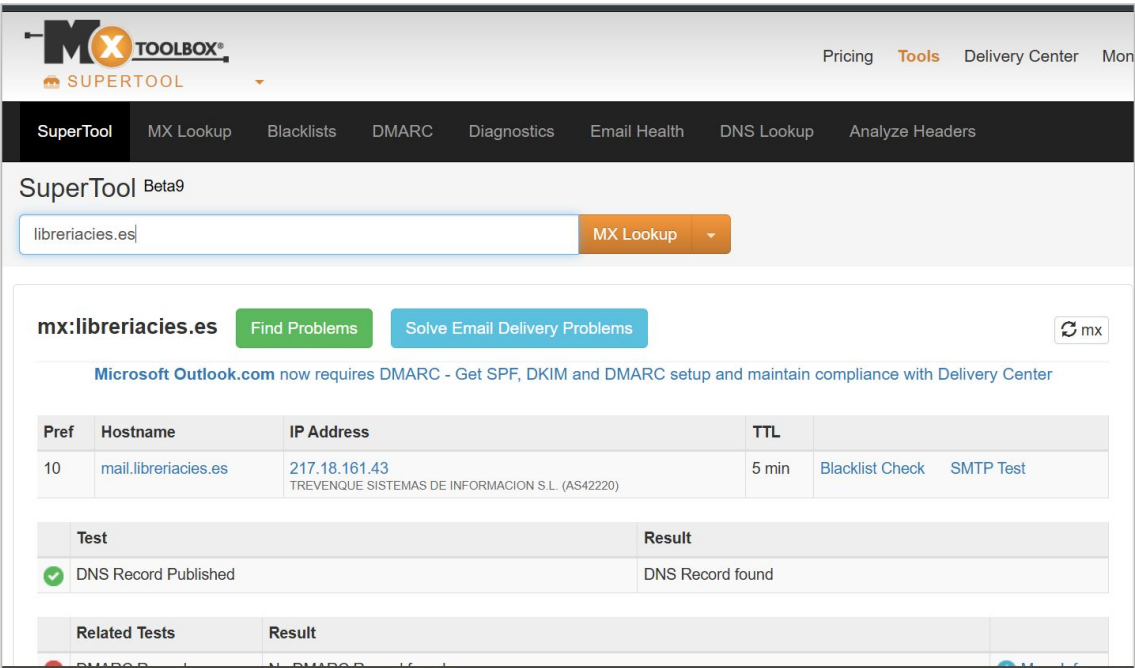


Figure 2 — MXToolbox lookup for libreriacies.es. A single MX record resolves to 217.18.161.43 (AS42220, Spain). The related tests panel reports no DMARC record found.

5.2 Hosting infrastructure and exposed services

Passive DNS mapping via DNSDumpster confirmed the mail host and enumerated the services exposed on 217.18.161.43:

```
Host : mail.libreriacies.es
IP : 217.18.161.43
ASN : AS42220 — SIAPI-AS, Trevenque Sistemas de Información S.L. (ES)
Netblock : 217.18.160.0/20
Reverse DNS : serlogal.arnoia.com

Exposed services:
ssh : SSH-2.0-OpenSSH_8.0
ftp : ProFTPD (port 20)
http : nginx — “Web Server”
https : nginx — Plesk Obsidian 18.0.74
```

The reverse DNS entry (serlogal.arnoia.com) differs from the mail hostname, and the host presents a **Plesk Obsidian control panel** alongside SSH, FTP and nginx. Taken together, this is the signature of a **shared commercial web-hosting server** serving many unrelated customer domains — not dedicated attacker infrastructure.

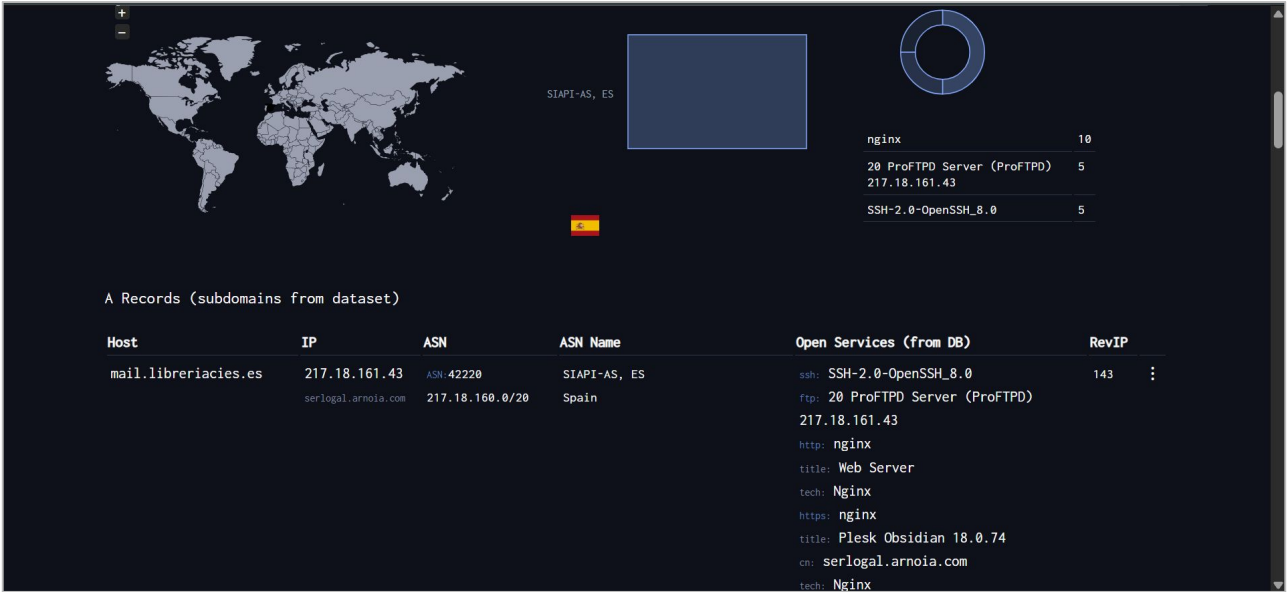


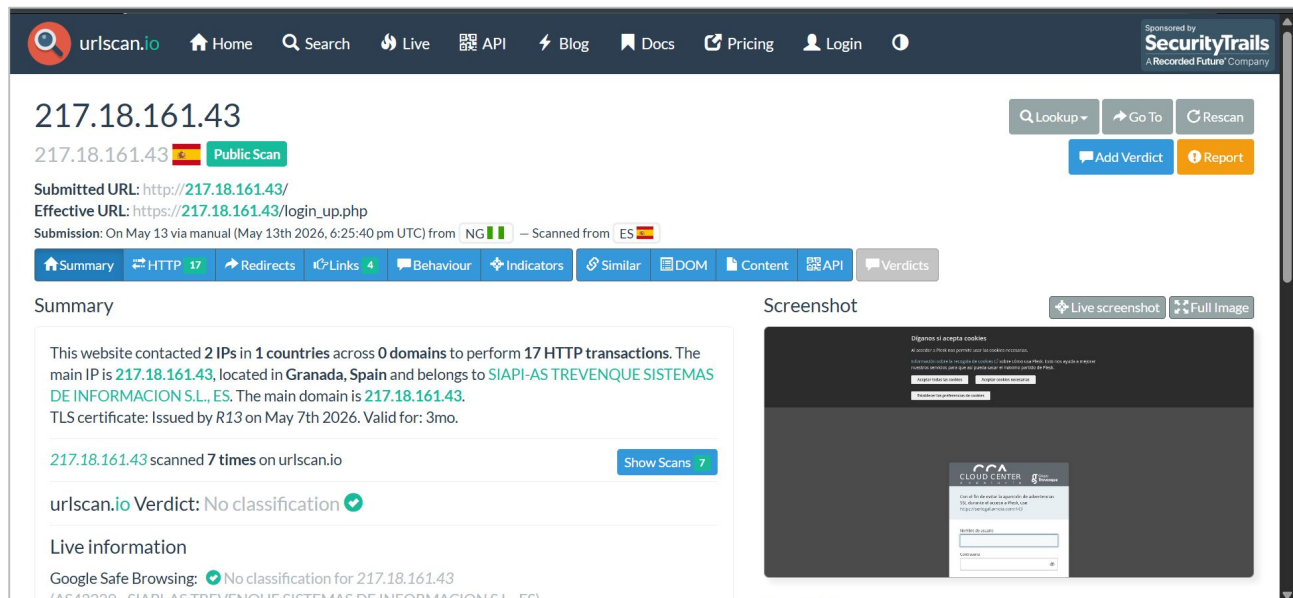
Figure 3 — DNSDumpster infrastructure mapping. Services exposed on 217.18.161.43 include SSH, FTP and nginx fronting a Plesk Obsidian control panel.

Interpretation — open services are context, not proof

The presence of SSH and FTP on this host does not by itself indicate attacker remote-access tooling. These are standard management services found on virtually every shared hosting server. Their significance here is different and more useful: they broaden the attack surface of a multi-tenant box. A single weak or reused customer credential on such a platform is one of the most common routes by which a legitimate business domain is taken over and repurposed to send phishing — which is the most probable explanation for what is observed in this case.

5.3 Reputation assessment of sender infrastructure

A urlscan.io scan of 217.18.161.43 returned a verdict of **No classification**, with Google Safe Browsing likewise returning no classification. The scan rendered a **Plesk control-panel login page** at https://217.18.161.43/login_up.php, contacting 2 IPs across 17 HTTP transactions, with a TLS certificate issued 7 May 2026 valid for three months.



The screenshot displays the urlscan.io interface for a scan of IP 217.18.161.43. The top navigation bar includes links for Home, Search, Live, API, Blog, Docs, Pricing, and Login. The main header shows the IP address and a 'Public Scan' label. Below this, the 'Submitted URL' is <http://217.18.161.43/> and the 'Effective URL' is https://217.18.161.43/login_up.php. The submission date is May 13, 2026, via manual. The scan shows 17 HTTP transactions, 0 domains, and a main IP of 217.18.161.43 in Granada, Spain. The verdict is 'No classification'. A screenshot of the Plesk control-panel login page is shown on the right. The page contains a login form with fields for 'Email or phone' and 'Password', and a 'Log in' button. The page also displays a 'Cloud Center' logo and a 'Log in' button.

Figure 4 — urlscan.io analysis of 217.18.161.43. The host serves a Plesk control-panel login page and carries no adverse classification at the time of scanning.

Why a clean sender IP does not exonerate the message

This unclassified result is entirely consistent with the compromise hypothesis rather than contradicting it. Shared hosting IPs carry legitimate traffic for many tenants, so reputation services are slow to blacklist them and often never do — precisely why attackers favour them. The absence of an adverse rating on the *sending infrastructure* carries little weight when the *message content* impersonates a major brand and the *payload link* is independently flagged as phishing. Verdicts must rest on the totality of evidence.

6. Embedded URL Analysis

The embedded link was submitted to VirusTotal and urlscan.io for passive analysis. It was not opened in a live browser at any stage.

6.1 Multi-engine reputation — VirusTotal

VirusTotal returned **4 of 92 security vendors flagging the URL as malicious**, with a community score of 2. The flagging vendors and their classifications were:

Vendor	Verdict
Fortinet	Phishing
G-Data	Phishing
SafeToOpen	Phishing
ADMINUSLabs	Malicious

The page was additionally tagged with **iframes**, **third-party cookies**, **trackers** and **external resources** — characteristics consistent with a credential-capture page that loads content from, and reports back to, external infrastructure.

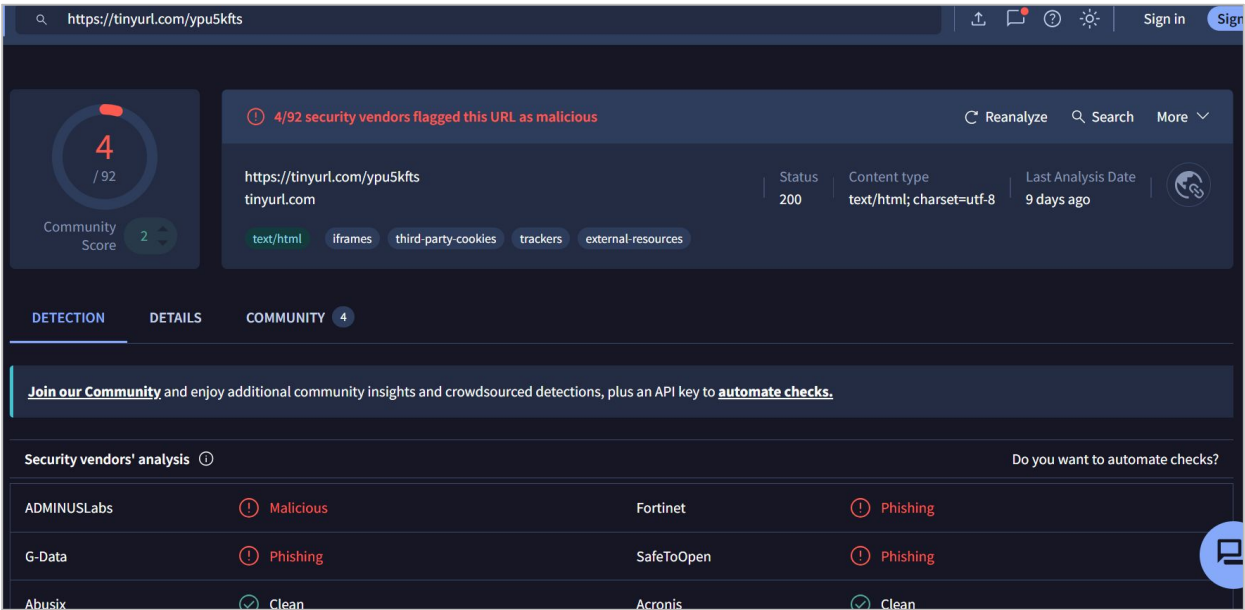


Figure 5 — VirusTotal detection summary. Four independent vendors classify the shortened URL as malicious or phishing.

Interpreting a 4-of-92 detection ratio

A low detection count must not be read as a low-risk indicator. Phishing pages are short-lived by design, and vendor coverage is always partial and lagging in the early hours of a campaign. Any non-zero detection for a **phishing** classification is significant, and four independent vendors converging on the same verdict is strong corroboration. Detection ratios establish a floor for suspicion, never a ceiling.

6.2 HTTP response metadata

Examination of the recorded HTTP response yielded the following:

Final URL	https://tinyurl.com/app/nospam/tinyurl.com/ypu5kfts
Serving IP	104.17.112.233 — Cloudflare (AS13335)
Status code	200
Body length	29.31 KB
Body SHA-256	787506f38a6d9e69a693f40b804c4f9f92c9330339cf367a9a0a0816ddf459a5

Most significant finding in this section

The final URL resolves to TinyURL's own **/app/nospam/** interstitial. This is the warning page TinyURL serves once it has determined that a short link is being used abusively. In other words, the shortener provider has **independently and separately identified this exact link as spam or abuse and disabled the redirect**. This is corroborating evidence from a party with direct visibility into the link's true destination, and it substantially reinforces the malicious verdict.

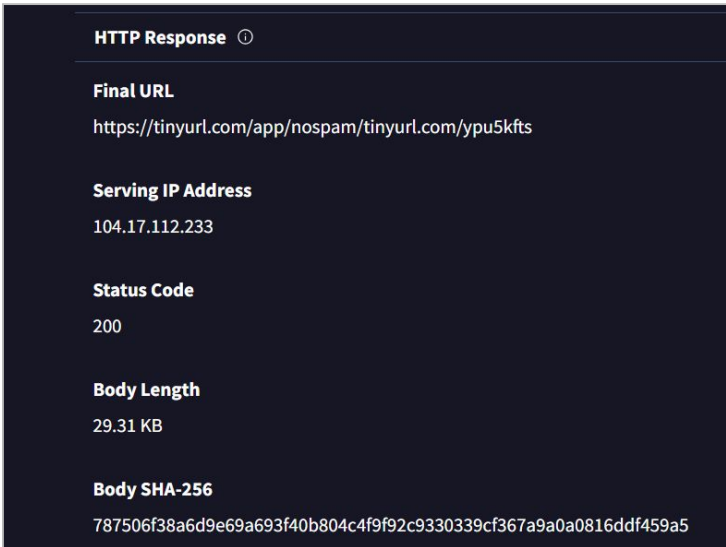


Figure 6 — HTTP response detail. The final URL lands on TinyURL's abuse interstitial, indicating the provider has flagged and disabled the short link.

6.3 Shortener domain reputation — attribution note

Separate checks were performed against the **tinyurl.com** domain itself. A DNS lookup returned Cloudflare-hosted A records (104.18.111.161 and 104.17.112.233), and urlscan.io reported the domain as 13 years old, scanned over 10,000 times, with a Cisco Umbrella rank of 21,869 and no adverse classification from Google Safe Browsing.

Important distinction — the shortener is not the threat

These results describe **TinyURL as a service**, which is an entirely legitimate, long-established URL shortener used by millions. The Cloudflare IP address is TinyURL's own CDN infrastructure, **not** attacker-controlled hosting, and it should not be recorded as an IOC or submitted for blocking. The malicious element is the **specific short link** /ypu5kfts and the destination it concealed. Blocking the tinyurl.com domain wholesale would generate substantial false positives without addressing the underlying threat.

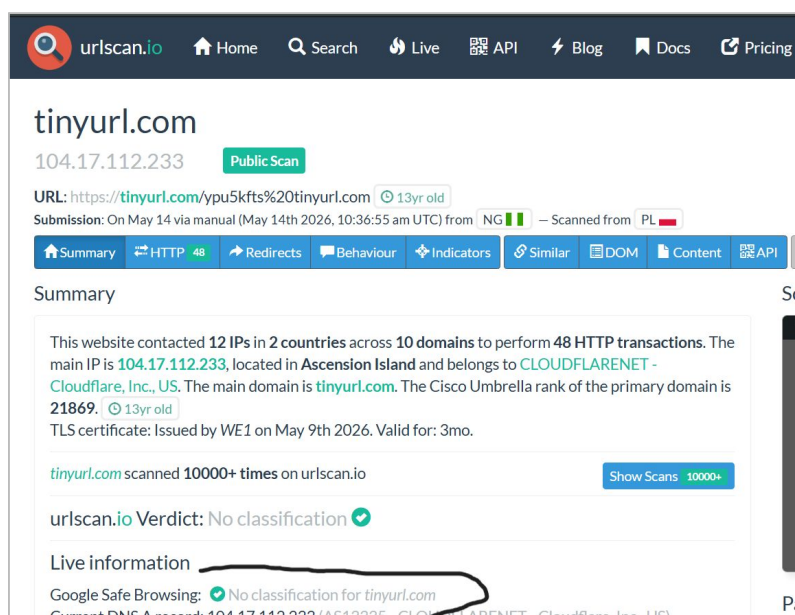


Figure 7 — urlscan.io profile for tinyurl.com. The shortener domain itself is well-established and unclassified; only the specific short link is malicious.

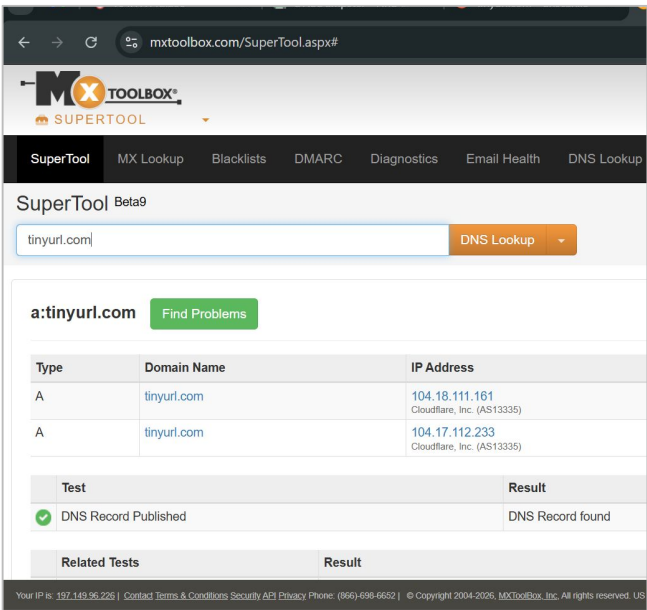


Figure 8 — DNS lookup confirming tinyurl.com resolves to Cloudflare infrastructure, which is the shortener's own CDN rather than attacker-controlled hosting.

7. Verdict & Justification

CONFIRMED PHISHING

The message is assessed with **high confidence** to be a credential-harvesting phishing attempt. The verdict rests on the convergence of independent evidence set out below.

7.1 Evidence supporting the verdict

- **Identity fraud is established beyond doubt.** The message claims to be from the Microsoft Security Team, yet was sent from `libreriacies.es`, a Spanish domain with no connection to Microsoft. No legitimate Microsoft security notification originates from third-party hosting in this manner.
- **The payload link is independently flagged.** Four separate vendors classify the embedded URL as malicious or phishing, and the page carries iframe, tracker and external-resource characteristics typical of a credential-capture form.
- **The shortener provider has confirmed abuse.** The link now resolves to TinyURL's own spam interstitial, which is served only after the provider determines a link is being used abusively. This is corroboration from a party with full visibility of the concealed destination.
- **The destination was deliberately concealed.** Using a shortener to hide the true target of a supposed security verification link has no legitimate purpose. Genuine providers link directly to their own authenticated domains.
- **The sending domain lacks DMARC.** The absence of any published enforcement policy removes a key defensive control and is consistent with a domain being abused for outbound phishing.
- **The social-engineering pattern is textbook.** Manufactured urgency, an arbitrary 24-hour deadline, a threat of account loss, a generic salutation, and an unsolicited attachment appear together in a single short message.

7.2 Addressing the apparently contradictory evidence

Two findings initially appear to point away from a malicious verdict, and both warrant explicit treatment so the conclusion is not misread.

The sender IP returned "no classification"

This is an absence of recorded evidence, not evidence of safety. `217.18.161.43` is a shared hosting server carrying legitimate traffic for numerous tenants; reputation services are correspondingly reluctant to blacklist such addresses. The unclassified result is fully consistent with the compromise hypothesis and does not weigh against it.

The sender domain's DNS records are correctly published

Valid MX and A records confirm only that the domain is properly configured for mail. This is a baseline operational fact true of virtually every domain on the internet, including every compromised one. It is not a reputation signal and carries no weight in either direction.

Most probable scenario

The evidence best supports **abuse of a legitimate but compromised third-party domain**. `libreriacies.es` appears to be a genuine Spanish business domain on a shared Plesk hosting platform whose mail function has been hijacked — most plausibly through compromised hosting or webmail credentials — and repurposed to distribute phishing. This pattern lets an attacker inherit the sending reputation of an established domain, which is precisely why the infrastructure returns clean verdicts while the message itself is unambiguously malicious.

8. Recommended Actions

8.1 Immediate containment

Priority	Action
CRITICAL	Do not click the embedded link and do not open the attachment. Preserve the message in place for evidentiary purposes rather than deleting it immediately.
CRITICAL	Block the specific short link <code>tinyurl.com/ypu5kfts</code> at the web proxy and mail gateway. Do not block the <code>tinyurl.com</code> domain wholesale.
High	Block or quarantine mail from <code>info@libreriacies.es</code> and, pending business justification, the wider <code>libreriacies.es</code> domain.
High	Search mail logs for other recipients of the same subject line, sender or short link to establish the true scope of the campaign.
High	If any user did interact with the link, treat their credentials as compromised: force a password reset, revoke active sessions and review sign-in logs for anomalous access.

8.2 Investigation and follow-up

- Retrieve and analyse the **full email headers**, which were not available for this assessment. Headers would confirm the true originating IP, the envelope sender, and the SPF and DKIM authentication results — materially strengthening attribution.
- Detonate the attachment in an **isolated sandbox** to determine whether it carries a second-stage payload or is merely a decoy supporting the lure.
- Submit the confirmed indicators to the organisation's threat intelligence platform and to relevant abuse channels, including the hosting provider (Trevenque Sistemas de Información S.L.) for the likely compromised domain.
- Hunt retrospectively across proxy and DNS logs for any historical resolution of the short link, which would indicate prior exposure.

8.3 Preventive and control improvements

- **Enforce DMARC, SPF and DKIM** validation on inbound mail and ensure the organisation's own domains publish an enforcing DMARC policy.
- **Apply external sender banners** to clearly mark mail originating outside the organisation, which substantially reduces susceptibility to brand impersonation.
- **Enable URL rewriting and time-of-click protection** at the mail gateway so that shortened and obfuscated links are resolved and evaluated at the moment of access.
- **Enforce phishing-resistant multi-factor authentication** so that harvested credentials alone are insufficient to access an account.
- **Deliver targeted user awareness training** using this message as a worked example, emphasising verification through official channels rather than links supplied in email.

Appendix A — Consolidated IOC list for blocking

EMAIL info@libreriacies.es
DOMAIN libreriacies.es
HOST mail.libreriacies.es
IP 217.18.161.43 (AS42220, Granada, ES)
URL hxtps://tinyurl[.]com/ypu5kfts
SHA256 787506f38a6d9e69a693f40b804c4f9f92c9330339cf367a9a0a0816ddf459a5

DO NOT BLOCK — legitimate infrastructure, listed for context only:
tinyurl.com (legitimate URL shortening service)
104.17.112.233 (Cloudflare CDN — TinyURL infrastructure)
104.18.111.161 (Cloudflare CDN — TinyURL infrastructure)

End of report. Prepared by Security Analyst — Incident Response. Classification: TLP:AMBER, internal use. All analysis conducted passively; no interaction with attacker-controlled infrastructure occurred at any stage.